

Informe HTMM.

El Hybrid Threat Modeling Method (hTMM) nació como un intento bastante protestante de tenerlo todo: alta cobertura de amenazas, pocos “falsos positivos”, resultados repetibles y cierto barniz de evidencia empírica, pero sin arruinar la cuenta de horas de consultoría. Desde 2025, las tendencias en sus indicadores y métricas se han ido desplazando hacia tres obsesiones muy poco románticas pero inevitables: capacidad de escalar a sistemas complejos (e infraestructuras país), trazabilidad cuantitativa del riesgo y alineación con marcos de ciber-resiliencia nacionales y europeos.¹²³⁴⁵⁶

1. Qué mide realmente hTMM (y qué no)

El informe técnico original de Carnegie Mellon/SEI deja algo muy claro: hTMM no es un “score” como CVSS ni un índice de madurez tipo NIST CSF, sino un proceso que genera insumos medibles para el análisis de riesgos. Su ambición declarada es reducir falsos positivos, no dejar amenazas fuera, ser consistente entre equipos y ser razonablemente coste-efectivo.⁷⁸⁹¹⁰¹¹

En la práctica, los indicadores de hTMM se agrupan en cuatro planos, que desde 2025 se están refinando sobre todo en contextos de sistemas ciber-físicos críticos y smart infraestructuras.¹²¹³¹⁴

1 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

2 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

3 <https://www.practical-devsecops.com/types-of-threat-modeling-methodology/>

4 <https://www.frontiersin.org/journals/computer-science/articles/10.3389/fcomp.2025.1647179/full>

5 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

6 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

7 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

8 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

9 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

10 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

11 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

12 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

13 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

14 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

1. Indicadores de cobertura de amenazas:

Número de amenazas distintas identificadas por sesión hTMM, desglosadas por tipo STRIDE (suplantación, manipulación, repudio, divulgación, DoS, elevación de privilegios).107

Proporción de amenazas “nuevas” respecto a métodos clásicos (solo STRIDE, solo árboles de ataque, etc.), utilizada como indicador de pensamiento “fuera de la caja” gracias a Security Cards.11127

Tasa de solapamiento entre equipos (qué porcentaje de amenazas es redescubierto por grupos independientes) como proxy de exhaustividad.12139

2. Indicadores de calidad del modelo de amenaza (consistencia y ruido):

Ratio amenazas válidas / amenazas descartadas en la fase de poda de Personae non Gratae (PnG).465

Dispersión de resultados entre equipos para un mismo sistema: varianza en número de amenazas y en clasificación por severidad, que el propio SEI usa como métrica de “consistencia inter-equipo”.13912

Densidad de falsos positivos: amenazas sin plausibilidad de vector de ataque creíble, que se pretende reducir mediante la combinación Security Cards + PnG.6114

3. Indicadores de esfuerzo (coste) del método:

Horas invertidas por rol (usuarios, ingenieros, expertos en ciberseguridad) en las fases de Security Cards, construcción y poda de PnG, y consolidación.14796

Número de artefactos analizados (DFD, requisitos, modelos arquitectónicos) frente a amenazas identificadas, para estimar productividad de la sesión hTMM.372

4. Indicadores de integración con el análisis de riesgo:

Número de amenazas que se traducen en requisitos de seguridad nuevos o modificados dentro de SQUARE u otro método de requisitos.782

Porcentaje de amenazas con estimación cuantitativa de impacto y probabilidad (cuando se combinan con matrices 5×5 o CVSS en métodos híbridos aparecidos a partir de 2024).9115

- Número de amenazas distintas identificadas por sesión hTMM, desglosadas por tipo STRIDE (suplantación, manipulación, repudio, divulgación, DoS, elevación de privilegios).107
- Proporción de amenazas “nuevas” respecto a métodos clásicos (solo STRIDE, solo árboles de ataque, etc.), utilizada como indicador de pensamiento “fuera de la caja” gracias a Security Cards.11127
- Tasa de solapamiento entre equipos (qué porcentaje de amenazas es redescubierto por grupos independientes) como proxy de exhaustividad.12139

- Ratio amenazas válidas / amenazas descartadas en la fase de poda de Personae non Gratae (PnG).465
- Dispersión de resultados entre equipos para un mismo sistema: varianza en número de amenazas y en clasificación por severidad, que el propio SEI usa como métrica de “consistencia inter-equipo”.13912
- Densidad de falsos positivos: amenazas sin plausibilidad de vector de ataque creíble, que se pretende reducir mediante la combinación Security Cards + PnG.6114
- Horas invertidas por rol (usuarios, ingenieros, expertos en ciberseguridad) en las fases de Security Cards, construcción y poda de PnG, y consolidación.14796
- Número de artefactos analizados (DFD, requisitos, modelos arquitectónicos) frente a amenazas identificadas, para estimar productividad de la sesión hTMM.372
- Número de amenazas que se traducen en requisitos de seguridad nuevos o modificados dentro de SQUARE u otro método de requisitos.782
- Porcentaje de amenazas con estimación cuantitativa de impacto y probabilidad (cuando se combinan con matrices 5×5 o CVSS en métodos híbridos aparecidos a partir de 2024).9115

Nada de esto viene con una “escala oficial hTMM 0-100”; lo que se ha consolidado son prácticas para convertir las salidas de hTMM en métricas de cobertura, consistencia y eficiencia que se puedan comparar entre organizaciones y, por extensión, entre sectores o países.¹⁵¹⁶¹⁷¹⁸

2. Tendencias desde 2025: de la aplicación al sistema a la aplicación al territorio

A partir de 2025 se aprecia una convergencia curiosa: el lenguaje de hTMM (cobertura de amenazas, consistencia, priorización) empieza a alinearse con el lenguaje de los informes de paisaje de amenazas y de las estrategias nacionales, incluso cuando estos no citan hTMM explícitamente.¹⁹²⁰²¹²²

En el plano metodológico, la tendencia dominante ha sido fusionar hTMM con marcos cuantitativos y catálogos táctico-técnicos:

15 https://www.sei.cmu.edu/documents/2308/2018_004_001_516627.pdf

16 <https://www.frontiersin.org/journals/computer-science/articles/10.3389/fcomp.2025.1647179/full>

17 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

18 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

19 <https://www.youtube.com/watch?v=ltD7Ysq0whc>

20 <https://www.frontiersin.org/journals/computer-science/articles/10.3389/fcomp.2025.1647179/full>

21 <https://www.sciencedirect.com/org/science/article/pii/S1526149224000122>

22 https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf

- Integración explícita con STRIDE + MITRE ATT&CK y CVSS en marcos de modelado y evaluación de riesgos para entornos smart (ciudades, redes inteligentes, transporte).¹¹⁵⁹
- Uso del “Hybrid” no solo como mezcla Security Cards + PnG + STRIDE, sino como paraguas para workflows que combinan árboles de ataque, scoring CVSS y taxonomías sectoriales.⁸⁹¹¹

En el plano macro (territorial), los informes Threat Landscape más recientes de ENISA se estructuran alrededor de indicadores que encajan muy bien en una lectura “hTMM a escala país”:

- Número de incidentes analizados (4.875 entre julio de 2024 y junio de 2025), con distribución por tipo de amenaza, vector inicial, sector afectado y actor.⁶²
- Peso abrumador de campañas de DDoS de bajo impacto pero altísimo volumen (en torno al 77% de incidentes), frente a un menor volumen pero mayor gravedad de ransomware y operaciones más sofisticadas.⁴¹²⁶
- Creciente convergencia entre actores hacktivistas y patrocinados por Estados, compartiendo herramientas y técnicas en un ecosistema híbrido de amenaza, muy acorde con la noción de PnG “Estado-marca” que uno podría modelar en hTMM.¹²⁴⁶

Aunque ENISA no marque en rojo “este indicador es del método hTMM”, el enfoque threat-centric y la insistencia en:

- cobertura de categorías de amenaza,
- contextualización por sector y actor,
- y necesidad de priorización basada en evidencia,

son precisamente las propiedades que el SEI definió como desiderata para hTMM y que, de facto, se están buscando replicar a escala de la UE y de los Estados miembros.²³²⁴²⁵²⁶

3. De indicadores hTMM a métricas nacionales: el caso de España

Si trasladamos estos elementos al contexto español, el juego consiste en “elevar” las métricas de hTMM desde el nivel de sistema/organización al nivel de dominio e infraestructura nacional, sin perder el espíritu híbrido (creatividad + filtro de realismo + priorización).²⁷²⁸

Un esquema razonablemente coherente con la práctica europea reciente sería:

²³ <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

²⁴ <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

²⁵ <https://www.youtube.com/watch?v=ltD7YsqOwhc>

²⁶ [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

²⁷ <https://www.youtube.com/watch?v=ltD7YsqOwhc>

²⁸ https://www.sei.cmu.edu/documents/2308/2018_004_001_516627.pdf

5. Cobertura de amenazas relevantes para España en el contexto UE:
Proporción de categorías de amenaza del informe ENISA presentes en los modelos de amenaza de sectores críticos españoles (energía, transporte, salud, administración pública).2126
Número de “nuevas” técnicas o vectores identificados en ejercicios de threat modeling nacionales que no estaban explicitados en catálogos previos (por ejemplo, usos específicos de IA generativa en campañas de desinformación o phishing avanzado contra la administración local).412
 6. Consistencia intersectorial:
Medida de divergencia entre modelos de amenaza de distintos operadores de un mismo sector (pensemos en varios proveedores de energía o de servicios sanitarios) respecto a un “núcleo” de amenazas reconocidas en el nivel UE.62
Número de amenazas “cruzadas” (por ejemplo, dependencias entre sector financiero y energía) que aparecen sistemáticamente en ejercicios hTMM multi-actor, indicador de madurez en el modelado de interdependencias.182
 7. Priorización y enlace con riesgo país:
Porcentaje de amenazas modeladas que disponen de una valoración cuantitativa (matrices de riesgo, scoring basado en CVSS adaptado a OT, etc.), siguiendo la línea de trabajos que combinan STRIDE, ATT\&CK y CVSS.5911
Relación entre amenazas de alta severidad en hTMM y las categorías “más impactantes” en los informes ENISA, para alinear priorización técnica con narrativa estratégica.246
 8. Esfuerzo y capacidad instalada:
Número de sesiones hTMM al año realizadas en operadores de servicios esenciales y administraciones clave, su duración media y composición (porcentaje de usuarios operativos, desarrolladores, expertos de ciber y responsables de negocio).1476
Ratio de amenazas identificadas por sesión frente a incidentes reales registrados en CSIRTs nacionales y sectoriales, como indicador grosero pero útil de “sensibilidad” del sistema de modelado respecto al terreno.1246
- Proporción de categorías de amenaza del informe ENISA presentes en los modelos de amenaza de sectores críticos españoles (energía, transporte, salud, administración pública).2126
 - Número de “nuevas” técnicas o vectores identificados en ejercicios de threat modeling nacionales que no estaban explicitados en catálogos previos (por ejemplo, usos específicos de IA generativa en campañas de desinformación o phishing avanzado contra la administración local).412

- Medida de divergencia entre modelos de amenaza de distintos operadores de un mismo sector (pensemos en varios proveedores de energía o de servicios sanitarios) respecto a un “núcleo” de amenazas reconocidas en el nivel UE.⁶²
- Número de amenazas “cruzadas” (por ejemplo, dependencias entre sector financiero y energía) que aparecen sistemáticamente en ejercicios hTMM multi-actor, indicador de madurez en el modelado de interdependencias.¹⁸²
- Porcentaje de amenazas modeladas que disponen de una valoración cuantitativa (matrices de riesgo, scoring basado en CVSS adaptado a OT, etc.), siguiendo la línea de trabajos que combinan STRIDE, ATT\&CK y CVSS.⁵⁹¹¹
- Relación entre amenazas de alta severidad en hTMM y las categorías “más impactantes” en los informes ENISA, para alinear priorización técnica con narrativa estratégica.²⁴⁶
- Número de sesiones hTMM al año realizadas en operadores de servicios esenciales y administraciones clave, su duración media y composición (porcentaje de usuarios operativos, desarrolladores, expertos de ciber y responsables de negocio).¹⁴⁷⁶
- Ratio de amenazas identificadas por sesión frente a incidentes reales registrados en CSIRTs nacionales y sectoriales, como indicador grosero pero útil de “sensibilidad” del sistema de modelado respecto al terreno.¹²⁴⁶

Con estos indicadores, hTMM se convierte en el motor de una métrica de madurez “de abajo arriba”: no es un sello mágico, pero alimenta el cuadro de mando nacional con datos sobre qué amenazas se contemplan, cómo se priorizan y con qué recursos cognitivos (actores, tiempo, diversidad de perspectivas) se llega a esas conclusiones.²⁹³⁰³¹³²

²⁹ <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

³⁰ https://www.sei.cmu.edu/documents/2308/2018_004_001_516627.pdf

³¹ <https://www.youtube.com/watch?v=ltD7Ysq0whc>

³² <https://www.sciencedirect.com/org/science/article/pii/S1526149224000122>

Tabla: Correspondencia conceptual hTMM - nivel país (UE/España)

Dimensión hTMM	Indicador operativo hTMM	Equivalente a escala nacional/UE
Cobertura de amenazas por categoría STRIDE	Número de amenazas por tipo STRIDE en cada sistema. 107	Cobertura de categorías de ENISA TL 2025 en sectores críticos. 62
Consistencia entre equipos	Varianza de amenazas y severidad entre grupos. 12139	Divergencias entre sectores y operadores en catálogos de amenaza. 6
Ruido / falsos positivos	Porcentaje de amenazas descartadas tras poda de PnG. 46	Diferencia entre amenazas previstas y no observadas en incidentes UE. 64
Esfuerzo de modelado	Horas por rol y sesión, artefactos analizados. 1479	Capacidad nacional en horas de análisis y número de equipos formados. 6
Priorización de riesgos	Severidad e impacto asignados a cada amenaza. 68	Alineación con categorías “top” de ENISA, matrices de riesgo país. 26
Generación de requisitos de seguridad	Número de requisitos nuevos derivados del modelo. 278	Cambios regulatorios, controles mínimos sectoriales, guías técnicas. 6

4. Comparativa mundial: de SEI a ENISA pasando por la industria

En el contexto global, hTMM convive con otros híbridos que persiguen objetivos similares pero con énfasis distintos: cobertura cuantitativa, automatización, o especialización en ciber-físico.³³³⁴³⁵³⁶³⁷

En Estados Unidos y el entorno anglosajón, el SEI sigue siendo el referente teórico de hTMM, con foco en:

- Uso de Security Cards para ensanchar el espacio de búsqueda de amenazas.¹¹¹⁴⁷
- Uso de PnG para filtrar actores y escenarios poco plausibles, manteniendo consistencia.⁵⁴⁶
- Integración con métodos de requisitos de seguridad (SQUARE) y, en algunos casos, con análisis cuantitativos posteriores.⁸⁹⁷

La industria ha adoptado el espíritu “híbrido” con otras combinaciones, más cercanas a la producción:

³³ <https://www.sei.cmu.edu/blog/threat-modeling-12-available-methods/>

³⁴ [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

³⁵ <https://www.frontiersin.org/journals/computer-science/articles/10.3389/fcomp.2025.1647179/full>

³⁶ <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

³⁷ <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

- Métodos cuantitativos que mezclan árboles de ataque, STRIDE y CVSS para dar una priorización numérica, especialmente en sistemas ciber-físicos complejos.⁹¹¹
- Marcos STRIDE + MITRE ATT&CK + CVSS para entornos smart, que en la práctica producen indicadores de riesgo muy similares a los que un hTMM enriquecería con Security Cards y PnG.58

En Europa, ENISA está empujando hacia un enfoque “threat-centric” e “intelligence-driven” que exige indicadores de:

- volumen y tipo de incidentes,
- actores dominantes (hacktivismo, crimen organizado, Estados),
- impacto funcional en servicios esenciales,

todo ello muy compatible con que los Estados miembros utilicen hTMM (o híbridos similares) para estructurar sus propias métricas de amenaza y riesgo.³⁸³⁹⁴⁰⁴¹

Para España, esto significa que la comparación mundial ya no se da tanto en “qué método usa cada uno”, sino en:

- cuán bien se conectan los ejercicios de threat modeling organizacionales con el paisaje de amenazas europeo;
- qué grado de cuantificación y priorización se consigue;
- y si el país es capaz de construir un “meta-modelo” de amenazas que, como hTMM, minimice ruido y puntos ciegos a escala nacional.¹²⁷⁶⁸

5. Una propuesta (inevitablemente propositiva) para operacionalizar hTMM en España

Si tomamos en serio el espíritu del método —crowdsourcing estructurado de amenazas, creatividad disciplinada, priorización basada en evidencia—, una hoja de ruta razonable para España podría consistir en:

³⁸ <https://www.sei.cmu.edu/blog/threat-modeling-12-available-methods/>

³⁹ <https://www.sciencedirect.com/org/science/article/pii/S1526149224000122>

⁴⁰ <https://www.gecad.isep.ipp.pt/pc2phish/en/panorama-de-ameacas-ciberneticas-europeas-principais-tendencias-do-enisa-threat-landscape-2025-eng/>

⁴¹ <https://smartstate.tech/blog/htmm-threat-modeling-method.html>

9. Establecer un núcleo de indicadores hTMM-inspirados obligatorios para operadores de servicios esenciales y administración:
Número y distribución de amenazas identificadas por categoría, actor y vector.1076
Ratio de amenazas que se traducen en controles o requisitos implementados en un periodo anual.768
Trazabilidad entre amenazas priorizadas y categorías top de ENISA Threat Landscape 2025.6212
 10. Normalizar una taxonomía de PnG “de país”:
Arquetipos que representen actores persistentes para España (grupos de ransomware, grupos hacktivistas alineados con intereses de Estados, insiders en sectores críticos, proveedores tecnológicos sistémicos).4126
Métrica asociada: frecuencia con que cada PnG aparece en los ejercicios de modelado y en incidentes reales, para ajustar el realismo de los modelos.564
 11. Enlazar formalmente hTMM con los marcos de riesgo y continuidad de negocio:
Exigir que las amenazas de severidad alta identifiquen explícitamente impactos en continuidad (MTD, RTO, RPO) y en los escenarios de planificación de continuidad y resiliencia.86
Incorporar indicadores de esfuerzo hTMM en los indicadores de capacidad de gestión de riesgos (por ejemplo, número mínimo de horas de modelado de amenaza/año por sector crítico).976
 12. Aprovechar la comparación internacional no tanto como ranking, sino como espejo:
Comparar la distribución de amenazas nacionales (por ejemplo DDoS masivo de bajo impacto, ransomware de alto impacto, operaciones híbridas) con las curvas europeas de ENISA para detectar sobrerrepresentaciones o ceguera selectiva.21264
Usar la evidencia empírica de métodos híbridos similares (Quantitative TMM, HyVAW, etc.) para justificar inversiones en automatización parcial de scoring y correlación con vulnerabilidades y eventos reales.1189
- Número y distribución de amenazas identificadas por categoría, actor y vector.1076
 - Ratio de amenazas que se traducen en controles o requisitos implementados en un periodo anual.768
 - Trazabilidad entre amenazas priorizadas y categorías top de ENISA Threat Landscape 2025.6212
 - Arquetipos que representen actores persistentes para España (grupos de ransomware, grupos hacktivistas alineados con intereses de Estados, insiders en sectores críticos, proveedores tecnológicos sistémicos).4126
 - Métrica asociada: frecuencia con que cada PnG aparece en los ejercicios de modelado y en incidentes reales, para ajustar el realismo de los modelos.564

- Exigir que las amenazas de severidad alta identifiquen explícitamente impactos en continuidad (MTD, RTO, RPO) y en los escenarios de planificación de continuidad y resiliencia.⁸⁶
- Incorporar indicadores de esfuerzo hTMM en los indicadores de capacidad de gestión de riesgos (por ejemplo, número mínimo de horas de modelado de amenaza/año por sector crítico).⁹⁷⁶
- Comparar la distribución de amenazas nacionales (por ejemplo DDoS masivo de bajo impacto, ransomware de alto impacto, operaciones híbridas) con las curvas europeas de ENISA para detectar sobrerrepresentaciones o ceguera selectiva.²¹²⁶⁴
- Usar la evidencia empírica de métodos híbridos similares (Quantitative TMM, HyVAW, etc.) para justificar inversiones en automatización parcial de scoring y correlación con vulnerabilidades y eventos reales.¹¹⁸⁹

Nada de esto exige convertir hTMM en ley orgánica ni elevar a dogma sus cinco pasos; basta con encarnar sus ideas de base en indicadores que permitan saber si el país, sus sectores y sus organizaciones:

- conocen suficientemente bien a sus adversarios,
- han explorado de forma creativa y sistemática sus vectores,
- y han sido capaces de priorizar con rigor qué amenazas de ese mosaico híbrido merecen atención inmediata.⁷⁶⁸⁴